

Clase 317 — Seguridad física y ambiental

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide, 9.^a ed. —
Chapple, Stewart & Gibson  Duración estimada: **110 min** · Nivel: **Intermedio**

Objetivo

Diseñar y evaluar **controles de seguridad física y ambiental** que protegen personas, equipos e información en instalaciones y centros de datos. La seguridad lógica se derrumba si alguien puede entrar a la sala de servidores; esta clase cubre desde CPTED y defensa en profundidad perimetral hasta HVAC, energía redundante y controles de acceso físico —temas del dominio de *Physical Security* de CISSP y Security+.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

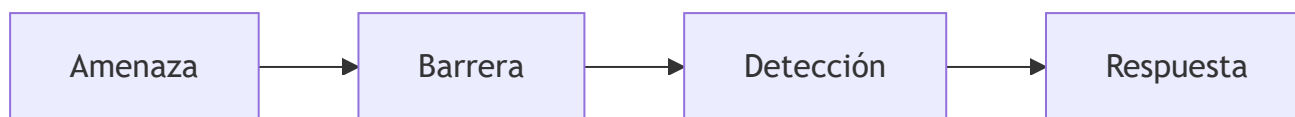
1. **Aplicar** los principios de CPTED (disuasión, retraso, detección, respuesta) al diseño de un sitio.
2. **Diseñar** una arquitectura de defensa en profundidad física por capas (perímetro → edificio → sala → gabinete).
3. **Especificar** requisitos ambientales de un centro de datos: HVAC, humedad, energía (UPS/generador) y supresión de incendios.
4. **Seleccionar** controles de acceso físico (mantraps, badges, biometría, tailgating prevention) según el nivel de riesgo.
5. **Evaluar** una instalación existente y producir una lista de hallazgos priorizada.

Temas

#	Tema	Por qué importa
1	CPTED (Crime Prevention Through Environmental Design)	Diseño del entorno para reducir oportunidad de ataque
2	Defensa en profundidad física por capas	Múltiples barreras entre el atacante y el activo
3	Controles de acceso físico	Badges, biometría, mantraps, turnstiles evitan intrusión
4	Tailgating / piggybacking	Vector humano que anula controles técnicos
5	HVAC, humedad y control ambiental	El calor y la humedad destruyen equipos y datos
6	Energía: UPS, generadores, PDU, redundancia	La continuidad depende de energía limpia e ininterrumpida
7	Supresión de incendios en salas de TI	Apagar fuego sin destruir los equipos
8	Tiers de centros de datos (Uptime Institute)	Clasifican disponibilidad y redundancia

Modelo mental y caso de decisión

La seguridad física diseña disuasión, detección, demora, respuesta y recuperación alrededor de personas y activos.



Caso razonado. Una puerta fuerte carece de alerta y procedimiento; el tiempo de demora no produce seguridad sin respuesta.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **CPTED:** metodología de diseño que reduce el delito mediante el entorno físico. Sus pilares son **vigilancia natural, control natural de accesos, refuerzo territorial y mantenimiento**. Característica clave: la prevención empieza en la arquitectura del sitio, no en el guardia.
- **Defensa en profundidad física:** capas concéntricas (cerca perimetral, iluminación, CCTV, recepción, puertas, sala, rack). Característica clave: fallar una capa no compromete el activo.
- **Mantrap / esclusa (access control vestibule):** doble puerta interbloqueada donde solo se abre una a la vez, con verificación entre ambas. Característica clave: neutraliza el *tailgating*.
- **Tailgating (piggybacking):** una persona no autorizada sigue a una autorizada a través de una puerta. Característica clave: derrota badges y biometría; se mitiga con esclusas, torniquetes y concienciación.
- **HVAC (Heating, Ventilation, Air Conditioning):** sistema que mantiene temperatura (~18–27 °C según ASHRAE) y humedad relativa (40–60 %). Característica clave: exceso de humedad → corrosión; defecto → electricidad estática.
- **UPS (Uninterruptible Power Supply):** batería que cubre el corte hasta que arranca el generador y **acondiciona** la energía (sags, spikes, brownouts). Característica clave: puente de segundos-minutos, no autonomía prolongada.
- **Supresión limpia (clean agent, p. ej. FM-200/Novec 1230):** apaga incendios sin residuos ni daño a electrónica, a diferencia del agua. Característica clave: protege equipos; requiere control de descarga por concentración de O₂.

- **Tiers Uptime Institute (I–IV):** clasificación de disponibilidad: Tier I (básico, sin redundancia) a Tier IV (tolerante a fallos, 2N+1). Característica clave: define objetivos de uptime (99.671 %–99.995 %).

Herramientas y preparación

Clase de evaluación de instalaciones; herramientas de campo y documentación:

- **Plano del sitio / floor plan** (draw.io o PDF del edificio) para marcar capas y controles.
- **Lista de verificación** basada en NIST SP 800-53 (familia **PE — Physical and Environmental Protection**).
- **Termómetro/higrómetro** o sensor IoT para medir condiciones reales de una sala de equipos.
- **Cámara** para documentar hallazgos (con autorización de la organización).
- **Estándar ASHRAE TC 9.9** como referencia de rangos térmicos para datacenters.

Toda evaluación física debe hacerse **con autorización escrita** del propietario de la instalación. Recorrer o fotografiar un sitio ajeno sin permiso es intrusión.

Laboratorio guiado — Evaluación física de una sala de servidores

Ejercicio aplicado: evaluarás (real o sobre plano) una sala de equipos y producirás un informe de hallazgos priorizado.

1. **Delimita el alcance.** Elige la instalación (sala de servidores, MDF/IDF o datacenter pequeño) y obtén autorización. Documenta límites y activos protegidos.
2. **Mapea las capas.** Sobre el plano, dibuja las capas de defensa: perímetro exterior, control de acceso al edificio, pasillo, puerta de la sala, gabinete/rack. Marca dónde hay control y dónde no.
3. **Evalúa acceso físico.** Verifica: ¿badge + PIN o solo badge? ¿Hay esclusa o torniquete? ¿Puertas con cierre automático? Registra riesgo de *tailgating* en cada punto.
4. **Evalúa vigilancia.** Ubica cámaras (cobertura, ángulos ciegos), iluminación, señalización territorial y retención de grabaciones (¿cumple política, p. ej. 30–90 días?).
5. **Mide condiciones ambientales.** Toma temperatura y humedad en frente y detrás de los racks (hot/cold aisle). Compara con rango ASHRAE 18–27 °C / 40–60 % HR.
6. **Revisa energía.** Confirma existencia de UPS, autonomía, prueba periódica del generador, PDUs redundantes (fuente A/B), y protección contra sobretensión.
7. **Revisa incendios.** Identifica detección temprana (VESDA/aspiración), tipo de supresión (clean agent vs sprinkler), y si el corte de energía (EPO) está protegido contra activación accidental.
8. **Puntúa cada hallazgo.** Usa una matriz probabilidad × impacto (Alto/Medio/Bajo) y prioriza.
9. **Redacta el informe.** Tabla de hallazgos con: control evaluado, estado, riesgo, recomendación y referencia a NIST 800-53 PE-x.

Entregable: informe de 1–2 páginas con la tabla de hallazgos priorizada y el mapa de capas anotado.

Ejercicios

1. Aplica los 4 pilares de CPTED al diseño de un estacionamiento corporativo.
2. Dibuja las capas de defensa en profundidad física de un datacenter Tier III.
3. Explica tres controles concretos contra tailgating y su costo/fricción relativa.

4. Calcula los minutos de autonomía de un UPS de 10 kVA con carga de 6 kW y banco de baterías dado (usa una hoja de cálculo).
5. Compara supresión por agua, gas inerte y clean agent para una sala con personal presente.
6. Justifica por qué un Tier IV usa topología 2N+1 y qué falla único tolera.

Reto verificable

Reto: produce el informe de evaluación física de una sala de equipos (real o sobre plano) con mapa de capas y tabla de hallazgos priorizada.

Criterio de aceptación:

- El mapa muestra al menos 4 capas de defensa en profundidad.
- Cada hallazgo tiene estado, nivel de riesgo (P×I) y recomendación accionable.
- Se evalúan las tres dimensiones ambientales: acceso, clima (HVAC) y energía.
- Cada recomendación referencia un control de la familia PE de NIST SP 800-53.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Tengo biometría pero entran extraños"	Tailgating: la biometría no impide que alguien pase detrás. Añade esclusa/torniquete y concienciación.
"La sala se sobrecalienta pese al AC"	Mala gestión de flujo de aire (mezcla hot/cold aisle). Implementa contención de pasillos y paneles ciegos.
"El generador no arrancó en el corte real"	Falta de pruebas periódicas con carga. Programa pruebas mensuales y mantenimiento del combustible.
"Instalaron sprinklers sobre los racks"	El agua destruye electrónica. Evalúa clean agent (FM-200/Novec) o pre-action para salas de TI.
"El botón EPO se activó por accidente"	EPO sin tapa/guarda. Añade cubierta protegida y señalización clara.
"Las cámaras no cubren la puerta trasera"	Ángulos ciegos. Reubica cámaras y valida cobertura con recorrido físico.

Preguntas frecuentes

? ¿Cuál es la temperatura "correcta" de un datacenter? ASHRAE TC 9.9 recomienda un rango recomendado de 18–27 °C y humedad relativa de 40–60 %. Operar más fresco gasta energía sin beneficio; más caliente acorta la vida del hardware.

? ¿UPS o generador? Ambos. El UPS cubre los segundos hasta que el generador arranca y acondiciona la energía; el generador provee autonomía prolongada. Son capas complementarias, no alternativas.

? ¿Por qué CPTED antes que guardias y cámaras? Porque diseñar el entorno para disuadir y controlar accesos de forma natural reduce la carga sobre los controles activos (guardias, CCTV) y baja el costo total. La detección y respuesta se apoyan en un buen diseño de base.

? ¿Qué diferencia un Tier III de un Tier IV? Tier III es *concurrentemente mantenible* (puedes dar mantenimiento sin apagar), Tier IV es *tolerante a fallos* (soporta un fallo único de cualquier componente sin caída), con redundancia 2N+1.

Referencias

- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.ª ed., Sybex — Dominio 3 (Physical Security).
- NIST. *Security and Privacy Controls for Information Systems* — [SP 800-53 Rev.5](#), familia PE.
- ASHRAE Technical Committee 9.9. *Thermal Guidelines for Data Processing Environments*.
- Uptime Institute. *Tier Classification System* — uptimeinstitute.com.
- NFPA 75/76 — Standard for the Protection of Information Technology Equipment.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 316 — Modelos de seguridad y arquitectura \(Bell-LaPadula, Biba, Clark-Wilson\)](#)

Siguiente clase

[Clase 318 — Gestión del programa de vulnerabilidades](#)